

OWASP Top 10 Assessment — MediConnect

#	Category	Tests Performed	Result	Evidence	Finding IDs	Severity	Status
A01	Broken Access Control	IDOR testing on chat, prescriptions, unread; vertical privesc via admin registration; role middleware audit	Finding	Burp Repeater PoCs (4 critical findings)	AS-01, AS-03, AS-04, AS-06, AS-05	Critical	Remediated
A02	Cryptographic Failures	JWT algorithm review (HS256), password hashing (bcrypt), TLS assessment, secret storage	Finding	Semgrep SG-02 (TLS bypass), hardcoded JWT secret in .env	SG-02	Low	Accepted Risk
A03	Injection	SQL injection via parameterized query audit, XSS via input sanitization review, command injection review	Pass	All DB queries use \$1, \$2 parameterized syntax; Zod input validation on forms	—	—	Pass
A04	Insecure Design	Business logic review, AI authorization architecture, missing rate limiting	Finding	No rate limiting on login; AI access not role-restricted (before fix)	AS-08	Medium	Partially Fixed

#	Category	Tests Performed	Result	Evidence	Finding IDs	Severity	Status
A05	Security Misconfiguration	Helmet headers, CORS policy, debug mode, default credentials, error leakage	Finding	Missing CSRF middleware (SG-01), permissive CORS in development	SG-01	Medium	Accepted Risk
A06	Vulnerable Components	npm audit (backend: 25, frontend: 67), Semgrep dependency check	Finding	jws < 3.2.3, engine.io, socket.io-parser CVEs	DEP-01	Low-High	Future Work
A07	Auth Failures	Token revocation, password policy, session management, brute-force testing	Finding	No token revocation on logout; no rate limiting	AS-07, AS-08	Medium	Partially Fixed
A08	Software & Data Integrity	CI/CD pipeline review, dependency integrity, code signing	Pass	package-lock.json integrity, GitHub Actions with security checks	—	—	Pass
A09	Logging & Monitoring	Security event logging, alerting, audit trail	Finding	No security logging existed (before fix)	—	Medium	Remediated
A10	SSRF	Server-side request patterns, AI API calls, external service integration	N/A	Application makes outbound calls only to Gemini API with hardcoded URL; no user-controlled URL parameters	—	—	N/A (no user-controlled URLs)

Summary

- **Findings:** 7 categories had findings
- **Pass:** 2 categories passed testing
- **N/A:** 1 category not applicable (with justification)
- **Total:** 10/10 OWASP Top 10 categories assessed
- **Remediated:** A01 (fully), A09 (fully), A04/A07 (partially)